

Security+ 5.2 · Risk Analysis

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.2 — Risk Analysis (9:13)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Análise: qualitativa (alto/médio/baixo) vs quantitativa (\$ — $SLE \times ARO = ALE$); risk appetite (o que a organização ACEITA — board define); risk tolerance (variação aceitável por área); risk register.

Highlights que a prova cobra

- $ALE = SLE$ (perda por incidente) $\times$ ARO (vezes/ano) — o quantitativo
- Appetite: o RISCO que aceita; tolerance: variação por área (operacional)

Dicas de prova & Cenários Típicos

- 'accepting a specific risk level per business unit' = risk tolerance

Cenário clássico de exame: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 5.2 — Risk Analysis)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. RTO (Recovery Time Objective) mede:

- A)** Quanto DADO você aceita perder
- B)** Quanto TEMPO o serviço pode ficar fora
- C)** O custo do incidente
- D)** O número de usuários afetados

2. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Appetite: o RISCO que aceita; tolerance: variação por área (operacional)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'accepting a specific risk level per business unit'=risk tolerance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo....

6. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'Appetite: o RISCO que aceita; tolerance: variação por área (operacional)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)...

8. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'accepting a specific risk level per business unit'=risk tolerance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B) Substituir controles técnicos preventivos por termos de adesão informais
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas
- D) Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance...

9. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo....
- B) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C) Substituir controles técnicos preventivos por termos de adesão informais
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Risk Analysis): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.2), um analista avalia o seguinte requisito técnico: 'ALE = SLE (perda por incidente) × ARO (vezes/ano)' — o quantitativo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B) Substituir controles técnicos preventivos por termos de adesão informais
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas
- D) Implementar a solução correspondente: ALE = SLE (perda por incidente) × ARO (vezes/ano) — o quantitativo...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Quanto TEMPO o serviço pode ficar fora.

✓ **Por que está certa:** A alternativa correta é: quanto TEMPO o serviço pode ficar fora. O RTO (Recovery Time Objective) é uma métrica central no Plano de Continuidade de Negócios (BCP) e no Plano de Recuperação de Desastres (DRP), abordada no domínio de Continuidade de Negócios e Recuperação de Desastres da CompTIA Security+ SY0-701. Ele define o tempo máximo aceitável para restaurar um serviço ou processo após uma interrupção, antes que o impacto no negócio se torne inaceitável. Por exemplo, se um e-commerce define RTO de 2 horas, a equipe de recuperação deve restabelecer a operação em até 2 horas após o incidente. O RTO orienta a escolha de estratégias de recuperação (hot site, warm site, cold site), a frequência de backups e os investimentos em redundância. Ele é frequentemente confundido com RPO, mas enquanto o RTO mede tempo de inatividade, o RPO mede perda de dados.

✗ **Por que as outras estão erradas:**

- *Quanto DADO você aceita perder:* Essa é a definição de RPO (Recovery Point Objective), não de RTO. O RPO estabelece a quantidade máxima de dados que pode ser perdida, medida em tempo (ex.: 15 minutos de transações). Ele determina a frequência dos backups: se o RPO é de 1 hora, os backups devem ocorrer pelo menos a cada hora. O RTO, por sua vez, foca no tempo de restauração do serviço, não na perda de dados. Confundir os dois conceitos leva a estratégias de recuperação inadequadas, pois um RPO baixo não garante um RTO baixo, e vice-versa.
- *O custo do incidente:* O custo do incidente é uma métrica financeira que quantifica as perdas diretas e indiretas decorrentes de uma interrupção (receita perdida, multas, produtividade, danos à reputação). Embora seja um insumo para justificar investimentos em continuidade, não é a definição de RTO. O RTO é uma meta de tempo, não um valor monetário. Utilizar o custo como definição de RTO desviaria o foco do planejamento de recuperação, que precisa de parâmetros temporais claros para orientar ações técnicas.
- *O número de usuários afetados:* O número de usuários afetados é uma métrica de impacto, útil para priorização e comunicação, mas não define o RTO. O RTO é um objetivo de tempo de recuperação, independentemente da quantidade de usuários. Um serviço crítico para poucos usuários pode ter RTO curto, enquanto um serviço para muitos usuários pode ter RTO mais longo, dependendo da criticidade para o negócio. Portanto, essa alternativa não corresponde ao conceito formal de RTO.

2) A — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) A — Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): Appetite: o RISCO que aceita; tolerance: variação por área (operacional).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'accepting a specific risk level per business unit'=risk tolerance.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: Appetite: o RISCO que aceita; tolerance: variação por área (operacional)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): Appetite: o RISCO que aceita; tolerance: variação por área (operacional).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: 'accepting a specific risk level per business unit'=risk tolerance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'accepting a specific risk level per business unit'=risk tolerance.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): 'perda por incidente de \$500k x 2/ano = ALE de \$1M/ano' — quantitativo..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.2 (Risk Analysis): $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.